



АКАДЕМИЯ
КОДЕБАЙ

ПРОФЕССИЯ ПЕНТЕСТЕР

Друзья, всех приветствую!

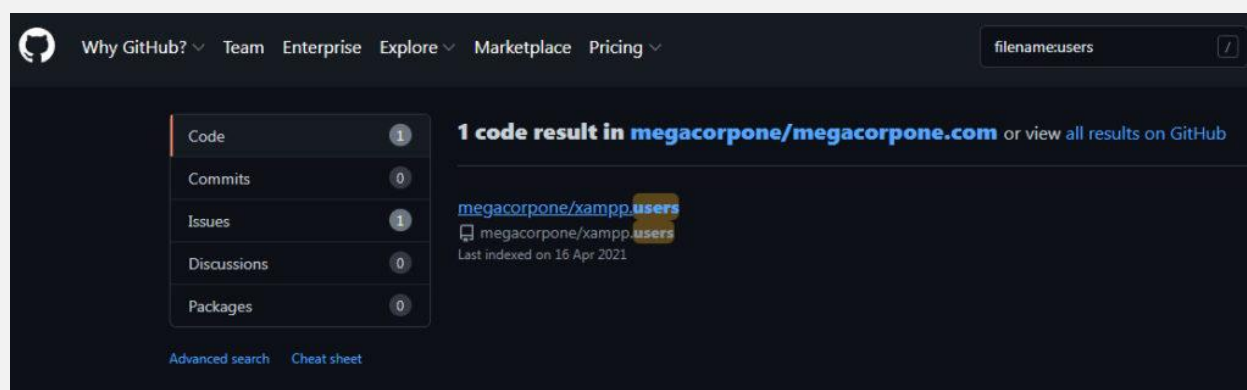
В этом уроке и следующих разделах мы обсудим различные онлайн-инструменты и ресурсы, которые можно использовать для пассивного сбора информации. Одними из таких источников информации являются проекты с открытым исходным кодом, такие как GitHub, Gitlab, и SourceForge.

Код, хранящийся в Интернете, может дать представление о языках программирования и системах, используемых в организации. В некоторых редких случаях разработчики даже случайно оставляли конфиденциальные данные и учетные данные в публичных репозиториях.

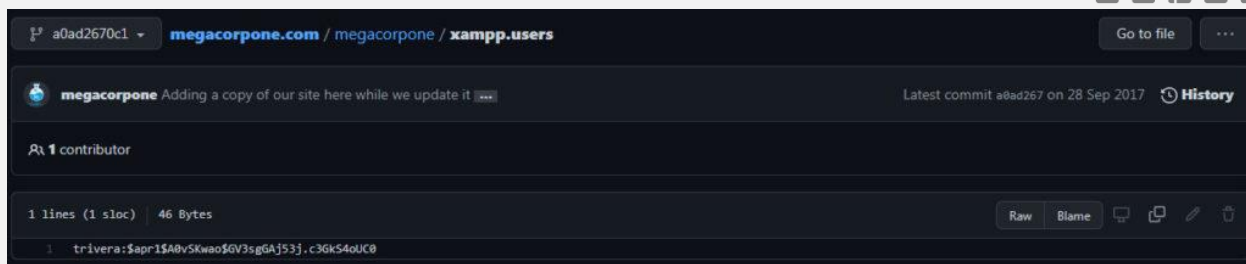
Инструменты поиска на некоторых из этих платформ поддерживают операторы поиска Google, которые мы обсуждали ранее.

Например, на [GitHub](#) мы можем искать в репозиториях пользователя или находить репозитории организации. Но для поиска по всем публичным репозиториям нам потребуется учетная запись.

Давайте проведем поиск интересной информации в репозиториях учетной записи MegaCorp One. Мы можем использовать `filename:users` для поиска любых файлов со словом "users" в имени файла:



Наш поиск обнаружил только один файл - `xampp.users`. Даже при единственном результате мы могли найти что-то очень интересное, поскольку XAMPP — это среда разработки веб-приложений. Давайте проверим содержимое этого файла:



Этот файл содержит хэш имени пользователя и пароля, который может оказаться очень полезным, когда мы начнем активную фазу атаки. Давайте добавим его в наши заметки.

Ручной просмотр репозиторий лучше всего подходит для небольших репозиторий. Для больших репозиторий мы можем использовать несколько инструментов, чтобы автоматизировать часть поиска, например, Gitrob и Gitleaks. Recon-ng также имеет несколько модулей для поиска на GitHub.

Работая с инструментами для поиска "секретов" в исходном коде, такими как Gitrob или Gitleaks, вы полагаетесь на регулярные выражения или энтропию для выявления потенциально полезной информации. Регулярные выражения — это заранее определенный поисковый шаблон. Они особенно полезны для поиска в тексте различных вариаций часто используемых паролей. Обнаружение на основе энтропии, позволяет найти строки, которые генерируются случайным образом. Идея заключается в том, что длинная строка случайных символов и чисел, скорее всего, является паролем. Независимо от того, как инструмент ищет "секреты", ни один инструмент не является совершенным, и он может пропустить то, что может обнаружить ручная проверка.